Saudi GRC Platform

Regulatory Mapping

Source: `regulatory-mapping.md`

07 — Regulatory Mapping Matrix

Cross-walk from regulatory source → platform module → workflow → data object → evidence → responsible role → compliance status.

Placeholder convention: where official control IDs were not provided in the source spec, the entries are tagged `*-PLACEHOLDER-NNN` and must be re-numbered when the official control library is imported.

Compliance-status options used throughout: `NOT_APPLICABLE | NOT_IMPLEMENTED | PLANNED | PARTIAL | IMPLEMENTED | VERIFIED`.

Gap-handling process: when status drops below `IMPLEMENTED`, the platform automatically opens a CAPA (`originType=compliance_gap`) and assigns it to the responsible role. Aging gaps escalate through the `AppetiteBreachFeed`.

NCA — Essential Cybersecurity Controls (ECC)

Source	Domain	Control / requirement	Summary	Module	Workflow	Data object	Evidence	Role	Status options	Report
NCA ECC	Governance	ECC-1-1 (seeded)	Cybersecurity strategy approved by management	Cyber	NCA Self-Assessment	CyberControl	Strategy doc	CISO	All	NCA Filing
NCA ECC	Governance	ECC-1-2 (seeded)	Cybersecurity policy framework	Cyber	NCA Self-Assessment	CyberControl + Policy	Policy PDF	CISO	All	NCA Filing
NCA ECC	Governance	ECC-1-3 (seeded)	Cybersecurity governance roles and responsibilities	Cyber	NCA Self-Assessment	CyberControl	RACI matrix	CISO	All	NCA Filing
NCA ECC	Defence	ECC-2-1 (seeded)	Asset management	Cyber	Asset Inventory	CyberAsset	Inventory snapshot	Asset Owner	All	NCA Filing
NCA ECC	Defence	ECC-2-5 (seeded)	Vulnerability management	Cyber	Vuln + Patch	Vulnerability	Scan report	Vuln Manager	All	NCA Filing
NCA ECC	Defence	ECC-2-9 (seeded)	Network security	Cyber	Control Assessment	CyberControl	Network diagram	CISO	All	NCA Filing
NCA ECC	Resilience	ECC-4-1 (seeded)	Cybersecurity resilience	Cyber	Resilience	CyberControl	Resilience plan	CISO	All	NCA Filing

Source	Domain	Control / requirement	Summary	Module	Workflow	Data object	Evidence	Role	Status options	Report
NCA ECC	TPRM	ECC-5-1 (seeded)	Third-party cybersecurity	TPRM	TPRM Cyber Assessment	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr	All	NCA Filing
(full library)		NCA-ECC-PLACEHOLDER-001..114	All 114 ECC main controls — to be imported from official library	Cyber	NCA Self-Assessment	CyberControl	Per control	CISO	All	NCA Filing

NCA — Cloud Cybersecurity Controls (CSCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA CSCC	Cloud	CSCC-1-1 (seeded, 32 controls)	Customer responsibilities for cloud cyber	Cyber	Cloud cyber assessment	CyberControl (CSCC)	Cloud pack	CISO + CIO	NCA Filing
(full library)		NCA-CSCC-PLACEHOLDER-001..N	Official CSCC controls — to import	Cyber	Cloud cyber	CyberControl	Per control	CISO	NCA Filing

NCA — Critical Systems Cybersecurity Controls (CCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA CCC	Critical Systems	CCC-1-1 (seeded, 30 controls)	Critical-system identification	Cyber	Critical-systems classification	CyberAsset	Classification	CISO	NCA Filing
(full library)		NCA-CCC-PLACEHOLDER-001..N	Official CCC controls — to import	Cyber	Critical systems	CyberAsset + CyberControl	Per control	CISO	NCA Filing

NCA — Operational Technology Cybersecurity Controls (OTCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA OTCC	OT/ICS	OTCC-1-1 .. OTCC-5-12 (seeded, 27 controls)	OT cyber security strategy, governance, operations, third-party, resilience	Cyber	OT cyber assessment	CyberControl	Per control	OT Cyber Lead	NCA Filing
(full library)		NCA-OTCC-PLACEHOLDER-001..N	Full OTCC v1.0 — to import	Cyber	OT cyber	CyberControl	Per control	OT Cyber Lead	NCA Filing

SAMA — Cyber Security Framework

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
SAMA Cyber	Leadership and Governance	SAMA-1.1.1 (seeded, 8 controls)	Cybersecurity governance	Cyber	NCA-style self-assessment	CyberControl	Charter	CISO	SAMA pack
SAMA Cyber	Operations	SAMA-3.3.1 (seeded)	Identity & access mgmt	Cyber	IAM + Privileged access	CyberControl	IAM evidence	CISO	SAMA pack
SAMA Cyber	TPRM	SAMA-4.4.1 (seeded)	Third-party cyber risk	TPRM	TPRM Cyber	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr	SAMA pack
SAMA Cyber	Resilience	SAMA-5.5.1 (seeded)	Incident response	Incident	NIST 800-61 lifecycle	CyberIncident	Incident report	CISO	SAMA pack
(full library)		SAMA-PLACEHOLDER-001..N	Full SAMA Cyber Security Framework — to import	Cyber/Comp	Per domain	Per	Per	Per	SAMA pack

SAMA — Outsourcing Rules (CCO-OUTS)

Source	Control	Module	Workflow	Data object	Evidence	Role
SAMA Outsourcing	Vendor risk management	SCM/TPRM	Vendor onboarding + assessment	Vendor + VendorAssessment	DD pack	Vendor Risk Mgr
SAMA Outsourcing	Exit planning	SCM	Supplier exit planning	ExitPlan	Exit plan doc	COO
SAMA Outsourcing	Resilience testing	SCM	Supplier resilience test	SupplierResilienceTest	Test after-action	Vendor Risk Mgr

Source	Control	Module	Workflow	Data object	Evidence	Role
SAMA Outsourcing	Fourth-party visibility	SCM	Fourth-party validation	FourthPartyExposure	Validation memo	Vendor Risk Mgr
(full library)	SAMA-PLACEHOLDER-OUT-001..N	SCM	Per	Per	Per	Per

SDAIA / PDPL

Source	Article	Requirement summary	Module	Workflow	Data object	Evidence	Role	Status options
PDPL	Art. 6	Lawful basis	Privacy	ROPA, DSA	ProcessingActivity, DSA	ROPA snapshot, DSA	DPO	All
PDPL	Art. 11	Consent	Privacy	Consent capture	Consent	Consent record	DPO	All
PDPL	Art. 12	Privacy notice	Privacy	Notice mgmt	PrivacyNotice	Published notice	DPO	All
PDPL	Art. 18	Retention + disposal	Privacy	Disposal certificate	DisposalCertificate	Disposal cert	Data Owner	All
PDPL	Art. 20	Breach (72h)	Privacy	Breach mgmt + Cyber-bridge	DataBreach	Notification, log	DPO + CISO	All
PDPL	Art. 22-26	DSR (30 days)	Privacy	DSR	DataSubjectRequest	Response pack	DPO	All
PDPL	Art. 28	Processor due diligence	Privacy	Processor assessment	Processor Assessment	Art. 28 pack	DPO	All
PDPL	Art. 29	Cross-border transfer	Privacy	CBT	CrossBorderTransfer	Approval pack	DPO	All
PDPL	Art. 31	ROPA	Privacy	ROPA	ProcessingActivity	ROPA snapshot	DPO	All
PDPL	Art. 35	Quarterly regulator evidence	Privacy + Reporting	Regulator pack	Multi	Quarterly packet	DPO	All
PDPL implementing regs	PDPL-PLACEHOLDER-001..N	Implementing regulations — to import	Privacy	Per	Per	Per	DPO	All

DGA — Digital Government Authority

Source	Requirement	Module	Workflow	Data object	Evidence	Role
DGA	DGA-PLACEHOLDER-001..N	Digital service quality + security baseline	Compliance	Regulatory mapping	Requirement	Service evidence

Source	Requirement	Module	Workflow	Data object	Evidence	Role
DGA	DGA-PLACEHOLDER-DATA-001	Data sharing across govt	Privacy	DSA	DSA	DSA
DGA	DGA-PLACEHOLDER-INTEROP-001	API interoperability	API	Integration spec	n/a	API contract

National Risk Council / Resilience

Source	Requirement	Module	Workflow	Data object	Evidence	Role
NRC	NRC-PLACEHOLDER-001..N	National-resilience programme requirements	BCM	Crisis activation + BCP	CrisisEvent + BCP	Crisis log

ISO 22301 (BCM)

Source	Clause	Control	Module	Workflow	Data object	Evidence	Role
ISO 22301	4.1	Context	BCM	Charter	BcmPlan (charter)	Charter	BCM Mgr
ISO 22301	5.1	Leadership	BCM	Governance	Committee	Minutes	Exec
ISO 22301	6.1	Risk + opportunity	BCM	BCM Risk Assessment	Risk + BiaRecord	Assessment	BCM Mgr
ISO 22301	8.2	BIA + risk assessment	BCM	BIA	BiaRecord	BIA report	BIA Owner
ISO 22301	8.4	BCP + DRP	BCM	BCP/DRP	BcmPlan, DrPlan	Plan docs	BCM Mgr
ISO 22301	8.5	Exercise programme	BCM	Exercises + tests	BcmExercise, SupplierResilienceTest	After-action	BCM Mgr
ISO 22301	9.1	Performance	BCM	KPI monitoring	KRI/KPI	Quarterly report	BCM Mgr
ISO 22301	10.2	Nonconformity + CAPA	BCM	CAPA	CapaTask	CAPA log	BCM Mgr

ISO 27001 (ISMS)

Source	Annex A	Module	Workflow	Data object	Evidence	Role
ISO 27001	A.5 Information security policies	Compliance	Policy lifecycle	Policy	Signed policy	CISO
ISO 27001	A.6 Org of info sec	Cyber	Governance	CyberControl	Org chart	CISO
ISO 27001	A.7 HR security	IAM + Compliance	User mgmt	User	Onboarding evidence	HR

Source	Annex A	Module	Workflow	Data object	Evidence	Role
ISO 27001	A.8 Asset mgmt	Cyber	Asset inventory	CyberAsset	Inventory	Asset Owner
ISO 27001	A.9 Access control	Cyber	IAM + Privileged access	CyberControl	Quarterly recertification	CISO
ISO 27001	A.10 Cryptography	Cyber	Key mgmt	CyberControl	Key inventory	CISO
ISO 27001	A.11 Physical security	Cyber	Physical	CyberControl	Physical audit	Facilities
ISO 27001	A.12 Operations	Cyber	Ops	CyberControl	Per control	CISO
ISO 27001	A.13 Communications	Cyber	Network	CyberControl	Per control	CISO
ISO 27001	A.14 Acquisition + dev + maintenance	Cyber	SDLC	CyberControl	SDLC evidence	CISO
ISO 27001	A.15 Supplier relationships	TPRM	TPRM cyber	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr
ISO 27001	A.16 Incident mgmt	Incident	NIST 800-61	CyberIncident	Incident report	Incident Mgr
ISO 27001	A.17 BCM	BCM	BCM	BcmPlan + DrPlan	Plans	BCM Mgr
ISO 27001	A.18 Compliance	Compliance	Mapping	Requirement	Crosswalk	Compliance

ISO 31000 (Risk)

Source	Clause	Module	Workflow	Data object	Evidence	Role
ISO 31000	5 Framework	ERM	Risk governance	Committee + Policy	Charter	Risk Mgr
ISO 31000	6.3 Risk identification	ERM	Risk identification	Risk	Register	Risk Mgr
ISO 31000	6.4 Analysis	ERM	Risk assessment	RiskAssessment	Assessment	Risk Mgr
ISO 31000	6.5 Evaluation	ERM	Treatment	TreatmentPlan	Treatment doc	Risk Mgr
ISO 31000	6.6 Treatment	ERM	Treatment	TreatmentPlan + CAPA	Action items	Risk Mgr
ISO 31000	6.7 Recording + reporting	Reporting	Board reports	Report	Board pack	Board Sec

ISO 27701 (Privacy ISMS)

Source	Clause	Module	Workflow	Data object	Evidence	Role
ISO 27701	Controller + processor extensions to ISO 27001	Privacy	PIA, processor DD, breach	ProcessingActivity, ProcessorAssessment	Per control	DPO
ISO 27701	PLACEHOLDER	(full mapping pending official import)	Privacy	Per	Per	Per

Gap handling process

1. When an assessment marks a control / requirement below `IMPLEMENTED`, the system records a gap on the linked CyberControl / ComplianceRequirement.
2. The compliance service auto-opens a CAPA (`originType=compliance_gap`, `originId=`) with severity matching the regulator's priority tier.
3. The CAPA owner receives an email + dashboard notification.
4. Aging unresolved gaps escalate to the appropriate committee through the `AppetiteBreachFeed`.
5. On CAPA closure with verified evidence, the assessment status is re-evaluated; if back to `IMPLEMENTED` the gap is closed.

Report output

The regulatory mapping powers:

- **Board Risk Report** — aggregated compliance % per regulator.
- **NCA Filing PDF** — per-control attestation export.
- **PDPL Compliance Report** — per-article coverage.
- **SAMA Quarterly Pack** — outsourcing + cyber + resilience.
- **Regulatory Evidence Package** — zip per regulator on-demand.